WorkCoPilot

WorkCoPilot Security and Privacy

How we help you do your work without taking your data

AdmireVeda | Rev 1.1 | October 2026

1. In one page

WorkCoPilot sits beside you and guides you through your work, one step at a time, by reading your screen and telling you the next move. It is read-only: it never clicks, types, runs a command, sends a message, or changes anything for you. You stay in control and do every action yourself.

This paper explains, in plain terms, what we do to protect your data and your work, what actually leaves your computer and what does not, how documents and screenshots are handled, and the security disciplines built into the guidance itself. It is written for a security or privacy reviewer but avoids unnecessary jargon.

> **The short version**
>
> Sensitive data (emails, IDs, card and account numbers, keys and secrets, private addresses) can be stripped or replaced with device-only tokens before anything is sent, so the real values never leave your machine. Documents on the installed app are read on-device and used only for that task. The AI is told to give you the secure way to do everything and to re-check its own commands and code for vulnerabilities before handing them over. We never act on your behalf, and we never sell or share your data.

2. Our principles

- Read-only by design. The product observes and guides. It cannot act, so it cannot make a change you did not make yourself.
- Data minimization. We send the least that is needed to give you the next step, and we give you controls to send even less.
- On-device first. Where we can keep sensitive data on your machine and still help you, we do. The redaction and tokenization engine runs on your device before anything is transmitted.
- Defense in depth. The same protection runs again on the server, so a control is enforced even if the first layer is bypassed.
- Secure by default in the guidance. Every command, script, config, and piece of code we suggest is the secure way to do it, and it is checked for common vulnerabilities before you see it.
- Honest about what we keep. This paper states plainly where data is kept, for how long, and the few cases where a convenience (for example uploading a document on the web) means text is stored on the server.

3. What WorkCoPilot is, and is not

WorkCoPilot is a screen-aware guide. It reads what is on your screen, works out the next concrete step for your goal, shows you exactly what to do, then watches for the result and reacts, like an expert working next to you.

It does	Read the screen you choose to share, plan the task, show the exact step, command, or setting, and confirm each step worked before moving on.

It does not	Click, type, run commands, submit forms, send messages, move money, or change any setting. There is no automation path that acts for you.

Because the product is read-only, an attacker who somehow influenced its output still could not make a change on your systems. Only you can, by choosing to follow a step.

4. What actually leaves your device

To give you a step, the product sends a short description of your goal and, when you ask it to read the screen, an image of the screen, to an AI model. Before any of that leaves your device, it can be cleaned by our data-protection engine.

4.1 The data-protection engine (DLP)

A single redaction engine runs on both your device and our server (one engine, used twice, so the rules can never drift apart). On your device it cleans outbound text before it is transmitted, so raw sensitive data never leaves the browser or app. On the server it runs again as a second line of defense. Nothing is ever silently dropped: you are shown a short summary of what was removed.

What it finds and removes from text:

Category	Examples it detects
Secrets and credentials	Private keys (PEM blocks), API keys and tokens (Stripe, AWS, GitHub, Slack, Google, JWTs), URLs that embed a username and password, and any value next to a label like password, secret, api key, access token, client secret
Government and financial IDs	Social Security / SIN numbers, credit card numbers (validated by the Luhn check so real cards are caught but version strings are not), IBANs, bank account and routing numbers
Contact details	Email addresses and phone numbers
Network identifiers	IPv4 and IPv6 addresses, and private or internal host and domain names (.local, .internal, .corp, and similar)
Health and personal records	Date of birth, medical record number, patient / member / policy / account numbers, driver license, passport, tax id, street address, and postal code, when they appear with a label or as real identifier values

What it deliberately keeps, so the guidance still works: public product domains (for example aws.amazon.com, github.com), file paths, commands, and version numbers. The model still learns there was "an email here" or "an IP here" from a typed placeholder, so the quality of the steps is preserved.

4.2 A real before-and-after

Suppose you type this goal (the sensitive values here are made up):

```
Open the firewall on 192.168.1.50 so admin@acme.com can reach SSH.
The DB password is Pg$ecret99 and patient MRN 48213 needs access.
```

With protection on, this is what actually leaves your device and reaches the server and the AI (redaction mode):

```
Open the firewall on [IP] so [EMAIL] can reach SSH.
The DB password is [REDACTED] and patient MRN [REDACTED] needs access.
```

The AI has enough structure to guide you ("there is an IP, an email, a password, and a medical record number"), but none of the real values. The step you get back is just as useful, and your data stayed with you.

4.3 Keeping the data on your computer: on-device tokenize and rehydrate

Redaction removes a value entirely. For teams who need the answer to come back with the real value filled in, there is a stronger mode that keeps the data on your computer and still gives you a complete answer.

In this mode, each sensitive value is replaced, on your device, with a stable token (for example [[IP_1]] or [[EMAIL_1]]). The token-to-value map is held in memory on your device only and is never transmitted. The server and the AI see only the tokens. When the answer comes back, your device substitutes the real values back into it, so you read a complete, usable answer while the sensitive data never left your machine.

> **What this means for you**
>
> A clinician can ask about "patient MRN 48213" and read an answer that names that exact MRN, while our server and the AI only ever saw [[DATA_1]]. The same value always maps to the same token within a session, so the guidance stays coherent, and the map is discarded when the session ends.

4.4 Screenshots

When you ask WorkCoPilot to read the screen, it sends an image of the area you are sharing to the AI so it can see what you see and give an accurate step. These live frames are used to read the screen in the moment; they are not collected into a gallery. If you choose to capture a step as evidence (for a report you are building), that screenshot is stored with your session so the report can include it, and you can delete it.

On the installed desktop app, the window is hidden from screen shares and recordings by default, so WorkCoPilot does not show up when you are presenting or on a call. You can toggle this when you want to deliberately show it.

5. Documents you add

You can give WorkCoPilot your own reference material (a runbook, a spec, a contract, a diagram) so the steps fit your environment. How that material is handled depends on where you are using the product.

Where	How your document is handled
Installed desktop app	The document is read and its text extracted ON YOUR DEVICE, including on-device OCR for images, diagrams, and scanned pages (the text recognition runs locally and works offline). The governed text is used only for that one task and is not stored on our server. The original file never leaves your machine.
Web app	The extracted text is stored on our server so it can be reused across your sessions. If data protection is on, it is cleaned by the DLP engine before any of it is sent to the AI. You can delete a document at any time, which removes its stored text.

If you are handling the most sensitive documents, the installed app is the stronger choice because the document is processed entirely on your device.

6. Enterprise data governance

For companies, an administrator can arm a data-governance policy that applies to everyone, so protection is not left to each person. The policy is enforced on the device and again on the server.

- Per-category actions. For each category (secrets, PHI, PII, IP, host, email, phone, card, SSN, IBAN) the administrator chooses what happens: send it, redact it, withhold it, or tokenize it (keep it on the device, as in section 4.3).
- Block words. Specific words or phrases (a project code name, a client name) are always removed before anything is sent, never guessed at.
- Custom fields. The administrator can add their own patterns (a word, a phrase, or a regular expression) and choose to redact or block each one, for data shapes unique to their business.
- Company-locked. A superadmin can lock the policy so a company administrator cannot weaken it.
- Transparency. Every scan records what was transmitted to the AI, and the person is shown a short summary of what was stripped on their device before sending.

7. Secure-by-default guidance

The biggest security risk in a guidance tool is not the plumbing, it is bad advice. A tool that tells you to paste a secret into a script, open a port to the world, or build a SQL query by gluing strings together has made you less safe. WorkCoPilot is built to do the opposite.

The guidance engine is instructed to hold itself to a security architect, a secure developer, a compliance manager, and a penetration tester at once, on every task in every field, not only on security work. Concretely, the guidance it gives:

- Defaults to least privilege and deny-by-default.

- Never puts secrets, keys, tokens, or passwords in code, URLs, logs, or shell history; it has you use an environment variable, a secrets manager, or paste the value at the prompt, and it tells you exactly where to get each value and where to put it.
- Parameterizes and validates input, and never builds SQL, shell, HTML, or file paths by string concatenation.
- Uses current, non-vulnerable versions and pinned dependencies, keeps traffic encrypted (TLS, HTTPS, SSH), and requires real authentication and authorization instead of wildcard or public exposure.

> **It checks its own work before you see it**
>
> Before it hands you a command or code, the engine is instructed to re-read its own output for the common vulnerability classes (injection, hardcoded secrets, over-broad permissions, insecure transport, missing authorization, unsafe deserialization, path traversal, SSRF, weak or home-made cryptography, a vulnerable version, world-readable or world-writable permissions) and fix it, so you never follow an insecure shortcut. If the only correct path has a security trade-off, it tells you and gives the safer alternative.

When you are doing authorized security testing (your own systems, a sanctioned engagement, a lab, or a CTF), it guides like a senior penetration tester, and it stops the moment a target or step is not yours or not authorized.

8. Platform and tenant security

Beyond the data in a single session, the platform that serves many companies is built so one customer can never reach another customer, and so access and billing cannot be quietly abused. These controls were independently reviewed and hardened.

- Tenant isolation. A company administrator can only ever see and change their own company. Every company-scoped action is checked twice, so there is no path to another company's people, usage, or data.
- Single sign-on, invite-only by default. Companies sign in with their own identity provider (Google, Microsoft, Okta, and other standard OpenID Connect providers) using the modern Authorization Code with PKCE flow. By default only people an administrator has added by email can sign in; everyone else is refused. Sign-in tokens are verified (issuer, audience, expiry, signature) and an unverified email is rejected.
- No account sprawl or seat abuse. License counts are enforced on every path, so a company cannot quietly exceed what it bought, and seats are reserved for the exact people an administrator chooses.
- AI keys never silently fall back. A company that chooses to run on its own AI keys is never silently switched to shared keys; if its keys are missing it is told, clearly.
- Encrypted transport, protected secrets. Traffic is served over HTTPS. Client secrets and API keys are stored server-side only and are never shown back in full; the signing key for the installed app is in the operating system's store.
- Signed installer. The desktop app is code-signed and timestamped, and updates are delivered over the signed update feed.

9. What we do not do

- We do not act on your behalf. No clicking, typing, running, sending, or changing anything.
- We do not sell or share your data.
- With protection on, we do not transmit your raw secrets, IDs, or private identifiers; in tokenize mode the real values and the token map never leave your device.
- On the installed app, we do not upload your reference documents; they are read on your device.
- We do not hide what left your machine: you are shown what was stripped, and administrators have an audit record of what was transmitted.

> **Honest caveats**
>
> Data protection is a control you turn on. For an individual account it is off until you or your company enables it; for companies an administrator can make it mandatory for everyone. On the web app, document text you upload is stored on our server (it is cleaned before reaching the AI when protection is on); if you need a document to stay entirely on your machine, use the installed app. Screenshots you capture as evidence for a report are stored with your session until you delete them.

10. How different customers benefit

Who	The benefit
Healthcare	A clinician or coder gets step-by-step help in the EHR while patient identifiers are tokenized on the device: the answer names the exact record, but our server and the AI only ever see a token. Supports a minimum-necessary posture.
Finance and accounting	Account, card, and routing numbers are stripped or tokenized before anything is sent, so reconciliation and finance work gets expert guidance without exposing account data.
Legal	Client names and matter codes can be added as block words so they are never transmitted, while the guidance still walks the contract review end to end.
Security teams	Authorized testing gets genuine penetration-tester guidance, and every command is checked for safety before it is run, on systems the tester confirms are theirs.
Regulated enterprises	A company-wide, locked data-governance policy, tenant isolation, single sign-on, and an audit record of what was transmitted give the controls and evidence that support a compliance program.

11. Controls at a glance

Control	What it protects	Where it runs
Read-only architecture	Your systems (nothing is changed for you)	Entire product
On-device redaction	Raw sensitive data in your text	Your device, before sending
On-device tokenize and rehydrate	The real values (they stay on your machine)	Your device
Server-side redaction	Defense in depth	Our server
On-device document reading and OCR	Your documents (installed app)	Your device
Governance policy, block words, custom fields	Company-defined sensitive data	Device and server
Secure-by-default guidance and self-check	You, from insecure advice	Guidance engine
Content protection	Your screen on shares and recordings	Installed app
Tenant isolation and invite-only SSO	One company from another	Platform
Encrypted transport, protected secrets, signed app	Data in transit and the software itself	Platform and installer
Transmission audit and redaction summary	Your ability to verify what left	Server and device

12. Audit and independent assurance

A claim about what leaves your device is only as good as your ability to check it. WorkCoPilot keeps a per-session audit log of exactly what was transmitted to the AI, so an operator, an internal auditor, or an independent third party can verify the protections for themselves rather than take them on trust.

12.1 What the audit captures

For every session, an append-only log records each transmission to the AI model. Each entry contains:

- A timestamp (UTC) for the transmission.
- The type of call: plan, watch (continuous screen reading), ask (a question about the screen), or a drill-down.

- The AI model that handled it, so you can see exactly which model was used, with no silent substitution.
- Whether data protection was on, and how many sensitive items were stripped on the device before sending.
- Whether a screen image was sent for that call.
- The exact text that reached the AI, which is the already-protected text, with sensitive values redacted or replaced by device-only tokens.

> **The audit proves the protection, and contains none of the secrets**
>
> Because sensitive values are stripped or tokenized on your device BEFORE transmission, the log shows the protected text that actually left. An auditor sees [EMAIL], [REDACTED], or a token where a real value was: that is the proof the control worked, and the log itself never stores the raw secret.

12.2 How an auditor triggers and reads it

- In the product, the person who ran a session can download that session's audit log at any time. A company superadmin can pull the audit log for any session in their company.
- The log is a plain, human-readable text file. It opens with a header (the session, the goal, and how many transmissions were logged) and then one block per transmission showing the timestamp, the call type, the model, whether redaction was on, how many items were stripped, and the exact text that was sent.
- During a session, the person is also shown a short live summary of what was stripped on their device before sending, for example "Stripped on your device before sending: 2 emails, 1 IP address."
- The logs are stored on the server with restricted file permissions and are not exposed to other users.

12.3 How a third party can validate the claims

An independent reviewer does not have to trust the description in this paper. The protections can be verified directly with a simple, repeatable test, and by reviewing the engine.

1. Run a controlled session with known markers. With data protection on, enter a goal that contains clearly identifiable test values: a test email, a fake card number that passes the checksum, a test IP address, and a labeled secret.
2. Download the session audit log. Confirm that every one of those values appears in the sent text as a placeholder or a token, and never as the original value. That is direct proof the sensitive data was removed on the device before anything was transmitted.
3. Confirm the model. Check that the model named in the log is the one configured, with no silent substitution.
4. Review the engine. The redaction and tokenization engine is a single, self-contained module used on both the device and the server, with a catalog of test cases covering each category it detects. A reviewer can read the rules and run the catalog.
5. For tokenize mode, confirm the map stays local. The token-to-value map is held in memory on the device, is never part of any request, and is never written to any log; the audit shows only the tokens.

> **What this gives an auditor**
>
> A reproducible, evidence-based check: inject known data, run a session, and read the audit log to see exactly what left the device. Combined with a review of the single-source protection engine and its test catalog, a third party can confirm the claims in this paper rather than accept them.

12.4 Scope and honest limits of the audit

- The audit records what was transmitted to the AI (the protected text and the model). It is a record of outbound data, not a full system access log.
- When data protection is off, the audit shows redaction as off and records the text as sent. That is itself useful, because it makes the setting and its effect visible.
- A screen image sent for a call is noted in the audit as "screen image sent"; the image itself is not embedded in the text log.
- The audit is per session. Retention and bulk export for a formal engagement can be arranged with AdmireVeda.

This document describes the security and privacy design of WorkCoPilot as built. Controls that are configurable (data protection, governance policy, AI key choice) are noted as such. For specific contractual or compliance commitments, contact AdmireVeda.